

منصة شاهين الرقمية
سياسة تشغيل منصة شاهين
الرقمية واستمرارية الأعمال

نوفمبر 2025



Internal

DO NOT COPY

الاسم المسجل : شركة الوثيقة الماسية لوساطة التأمين
المركز الرئيسي : طريق الثمامة , الربيع , الرياض
مسؤول المستند : مدير إدارة الجودة والتطوير

المحتويات	
1	المقدمة
2	الهدف من السياسة
3	تعريف
4	نطاق تطبيق السياسة
5	القطاعات والإدارات ذات العلاقة
6	الكيانات ذات العلاقة
7	قواعد عامة
8	مسؤولية السياسة
9	التعاميم والتعليمات ذات العلاقة
10	حفظ السياسة
11	مخالفة السياسة



إدارة الجودة والتطوير Quality & Development Management

المادة (1): يحتوي هذا المستند على المعلومات المتعلقة بمنصة شاهين الرقمية ولا يجوز استخدام أو نسخ هذا المستند أو المعلومات التي يحتوي عليها كاملة أو جزءاً منها أو كشفه إلى الغير ما لم تقدم شركة الوثيقة الماسية (دايموند) موافقتها الكتابية على ذلك. لا يجوز تعديل أو حذف هذا التصريح المقيد في أي حالة من هذا المستند.

المادة (2): في حال وجود اختلاف بين النص العربي والإنجليزي فإن السيادة تكون للنص العربي.



معلومات السياسة				
سياسة تشغيل منصة شاهين الرقمية واستمرارية الأعمال				عنوان السياسة
مُستحدثة				حالة السياسة
لا يوجد				عنوان السياسة السابقة
لا يوجد				تاريخ السياسة السابقة
بعد مُرور سنتين من تاريخ اعتماد السياسة أو عند الضرورة				تاريخ المراجعة القادمة
1SP0002				رقم المستند
منصة شاهين الرقمية				مالك السياسة
إدارة الجودة والتطوير				إعدت بواسطة
مسؤولو القطاعات والإدارات الذين راجعوا السياسة ووافقوا عليها				
التوقيع	التاريخ	الاسم	الوظيفة	الإدارة
	2025-12-28	تركي عبدالله العبدلي	مدير إدارة الإلتزام والامتثال	الإدارة الرقابية
	2025-11-26	عنه: هاني هاشم	مدير إدارة الجودة والتطوير	رئيس مراجعة السياسات
اعتماد السياسة				
	2025-12-28	بدر سعد الشايع	العضو المنتدب	الإدارة العليا



إدارة الجودة والتطوير
Quality & Development Management



DO NOT COPY

1. المقدمة:

1.1 تُعد سياسة تشغيل منصة شاهين الرقمية واستمرارية الأعمال جزءًا أساسيًا في بناء تنظيم تشغيل المنصة وصيانتها واستمراريتها بطريقة تضمن سلامة البيانات، واستمرارية الخدمة، وامتثال الشركة للمعايير التنظيمية والتقنية الصادرة عن هيئة التأمين وهيئة الحكومة الرقمية والجهات ذات العلاقة.

2. الهدف من السياسة:

2.1 تثق شركة الوثيقة الماسية لوساطة التأمين (ويشار إليها فيما يلي بـ "شاهين") في أن الهدف من هذه السياسة هو وضع إطار حوكمي وتشغيلي شامل يضمن استمرارية عمل منصة شاهين الرقمية دون انقطاع، من خلال إدارة الصيانة، النسخ الاحتياطي، معالجة الأعطال، إدارة المخاطر التقنية، وخطط التعافي من الكوارث (DRP) واستمرارية الأعمال (BCP).

3. تعاريف:

3.1 منصة شاهين (Shahin Platform): المنصة الرقمية التابعة للشركة، والمتخصصة في ربط المنصة كوسيط تأميني بشركات التأمين لتسهيل عمليات الإصدار والتجديد وإدارة العملاء إلكترونياً.

3.2 BCP (Business Continuity Plan) خطة استمرارية الأعمال: تهدف إلى استمرار الخدمات التشغيلية عند وقوع خلل أو طارئ.

3.3 DRP (Disaster Recovery Plan): خطة التعافي من الكوارث التقنية: وتحدد إجراءات استعادة الخدمة بعد وقوع حادث أو فقد بيانات.

3.4 CISO: مسؤول الأمن السيبراني في الشركة: المكلف بالإشراف على حماية الأنظمة وضمان الالتزام بالمعايير الأمنية.

3.5 Incident Response Team (IRT): فريق الاستجابة للحوادث التقنية: المعني بالكشف عن الأعطال أو الهجمات الإلكترونية ومعالجتها فوراً.

3.6 System Owner مالك النظام: المسؤول عن التشغيل والإشراف على سلامة الأداء الفني للمنصة.

3.7 Data Owner مالك البيانات: المسؤول عن دقة البيانات وحمايتها من الوصول غير المصرح به.

4. نطاق تطبيق السياسة:

4.1 تُطبق هذه السياسة على جميع الأنظمة والخوادم وقواعد البيانات والبنى التحتية الرقمية المتعلقة بمنصة شاهين، بما في ذلك عمليات التشغيل، المراقبة، الصيانة، الأمن السيبراني، النسخ الاحتياطي، وخطط التعافي من الكوارث.

5. القطاعات والإدارات ذات العلاقة:

5.1 إدارة تقنية المعلومات.

5.2 قسم الأمن السيبراني.

5.3 إدارة الجودة والتطوير.

6. الكيانات ذات العلاقة:

6.1 هيئة التأمين.

6.2 هيئة الحكومة الرقمية (DGA).

6.3 مزودو الخدمات التقنية الخارجيون.

7. قواعد عامة:

7.1 الالتزام العام

- 7.1.1 يجب على إدارة تقنية المعلومات ضمان التشغيل الآمن والمستمر لمنصة شاهين وجميع مكوناتها الرقمية، بما يشمل الأنظمة وقواعد البيانات والتكامل مع الجهات الداخلية والخارجية.
- 7.1.2 تلتزم الإدارة بتنفيذ خطة تشغيل يومية تشمل المراقبة، الصيانة، النسخ الاحتياطي، وإدارة الحوادث التقنية لضمان استمرارية الخدمة.
- 7.1.3 يجب أن تكون جميع أنشطة التشغيل متوافقة مع الأهداف الاستراتيجية للشركة ومتطلبات الأمن السيبراني الصادرة عن الجهات التنظيمية.
- 7.1.4 يُحظر إجراء أي تعديل أو تحديث أو إيقاف لخدمة رقمية دون موافقة مسبقة من مدير تقنية المعلومات ومسؤول الأمن السيبراني و توثق الموافقة الرسمية قبل تنفيذ أي تغيير.
- 7.1.5 يجب الحفاظ على جاهزية تشغيلية لا تقل عن 99% شهرياً، واتخاذ الإجراء التصحيحي الفوري عند أي انخفاض في الأداء.
- 7.1.6 يُحظر استخدام أي أنظمة أو برمجيات أو إضافات خارجية لم تعتمد رسميًا أو لم تُختبر في بيئة آمنة.

7.2 التشغيل الفني والصيانة

- 7.2.1 يجب مراقبة المنصة بشكل مستمر على مدار الساعة للكشف عن أي خلل أو توقف في الخدمة.
- 7.2.2 تُنفذ الصيانة الوقائية بجدول منتظم، ويجب معالجة الأعطال فور اكتشافها دون تأخير.
- 7.2.3 يُحظر تنفيذ الصيانة خلال أوقات الذروة التشغيلية إلا في الحالات الطارئة وبعد إشعار المستخدمين.
- 7.2.4 يجب أن تلتزم جميع عمليات التشغيل بمبدأ استقرار الأنظمة ومنع أي تأثير سلبي على المستخدمين النهائيين.

7.3 إدارة المخاطر التقنية

- 7.3.1 يجب تحديد وتحليل المخاطر التقنية بشكل دوري واتخاذ الإجراءات الوقائية لتفاديها مع توثيق نتائج التحليل ووسائل المعالجة المعتمدة.
- 7.3.2 تشمل المخاطر التشغيلية: فشل الأنظمة، ضعف أداء الموردين، أو الهجمات السيبرانية.
- 7.3.3 يجب تصعيد أي مخاطرة عالية التأثير إلى الإدارة التنفيذية فوراً واتخاذ الإجراء العاجل لمعالجتها.
- 7.3.4 يُحظر تجاهل أو تأجيل معالجة المخاطر المصنفة عالية أو حرجة لأي سبب.

7.4 الأمن التشغيلي والمراقبة

- 7.4.1 يجب تشغيل أنظمة كشف ومنع الاختراق (IDS/IPS) لمراقبة الأنشطة غير المصرح بها في المنصة.
- 7.4.2 تلتزم الإدارة بتفعيل قدرات الرصد والتنبيه التلقائي لأي تهديد أمني محتمل.
- 7.4.3 يُحظر تثبيت أي أدوات مراقبة أو جمع بيانات تشغيلية غير معتمدة رسميًا.
- 7.4.4 يجب تطبيق مبدأ الحد الأدنى من الصلاحيات على المستخدمين الإداريين والفنيين.

7.5 إدارة التغيير والتحديثات

- 7.5.1 يجب الحصول على موافقة مسبقة لأي تعديل أو تحديث في بيئة التشغيل مع توثيق طلبات التغيير واعتماداتها الفنية.
- 7.5.2 يُحظر تنفيذ أي تغيير في بيئة الإنتاج قبل اختباره بنجاح في بيئة تجريبية مستقلة توثيق نتائج الاختبار الفني والموافقة النهائية للنشر.

- 7.5.3 يجب اعتماد آلية مراجعة دورية لجميع التغييرات التقنية لضمان توافيقها مع خطة التطوير السنوية.
- 7.5.4 يُحظر تنفيذ أي تحديث خارج الجدول الزمني المعتمد إلا في حالات الطوارئ الموثقة فنيًا.

7.6 النسخ الاحتياطي واستعادة البيانات

- 7.6.1 يجب تنفيذ نسخ احتياطي تلقائي يومي لجميع الأنظمة وقواعد البيانات الحيوية.
- 7.6.2 تُحفظ النسخ الاحتياطية في مواقع منفصلة ومحمية من الوصول غير المصرح به.
- 7.6.3 يجب اختبار وتوثيق النسخ الاحتياطية بانتظام للتأكد من قابليتها للاستعادة.
- 7.6.4 يُحظر تعديل أو حذف النسخ الاحتياطية إلا بتفويض رسمي من مدير تقنية المعلومات.

7.7 استمرارية الأعمال (BCP):

- 7.7.1 يجب إعداد خطة استمرارية أعمال تضمن استمرار المنصة في تقديم الخدمات خلال أي خلل أو طارئ.
- 7.7.2 تشمل الخطة تحديد الأنظمة الحيوية، أولويات التعافي، وآليات التحويل التلقائي للخدمات الحيوية.

- 7.7.3 يجب اختبار وتوثيق جاهزية خطة الاستمرارية بشكل دوري للتحقق من كفاءتها وفعاليتها الاستجابة.
- 7.7.4 تُحدَّث خطة الاستمرارية فور حدوث أي تعديل جوهري في البنية التقنية أو نطاق التشغيل.
- 7.8 التعافي من الكوارث (DRP)
- 7.8.1 يجب وضع خطة تعافي من الكوارث تُمكن من استعادة المنصة خلال مدد زمنية محددة مسبقاً (RTO/RPO).
- 7.8.2 تتضمن الخطة إنشاء بيئة تشغيل بديلة يمكن تفعيلها مباشرة عند توقف النظام الأساسي.
- 7.8.3 يجب اختبار وتوثيق خطة التعافي مرتين سنوياً لضمان فعاليتها في استعادة الخدمة.
- 7.8.4 يجب أن تكون خطة التعافي متكاملة مع خطة الاستمرارية لضمان عدم انقطاع الخدمات الرقمية.
- 7.9 إدارة الحوادث التقنية
- 7.9.1 يجب إنشاء فريق استجابة للحوادث التقنية مزود بالصلاحيات والأدوات اللازمة لمعالجة الأعطال فوراً.
- 7.9.2 تعتمد إدارة الحوادث على دورة متكاملة تشمل: التحضير، الكشف، الاحتواء، المعالجة، التعافي، والتحسين.
- 7.9.3 يجب الإبلاغ عن أي حادث أمني أو تقني خلال ساعتين من اكتشافه عبر القنوات الرسمية.
- 7.9.3.1 يجب توثيق الحوادث الأمنية والتقنية بعد معالجتها (نوعها – التوقيت – المعالجة – الدروس المستفادة).
- 7.9.4 يُحظر تجاهل أو تأخير الاستجابة للحوادث التشغيلية أو الأمنية.
- 7.9.5 يجب تقييم أسباب الحوادث الدورية ووضع الإجراءات الوقائية لتجنب تكرارها.
- 7.10 إدارة الحوادث الأمنية (Incident Management):
- 7.10.1 يجب على إدارة تقنية المعلومات تطبيق إطار استجابة للحوادث الأمنية معتمد، يهدف إلى الكشف المبكر عن التهديدات ومعالجتها وتقليل أثارها التشغيلية.
- 7.10.2 تلزم الشركة بتطبيق دورة الاستجابة للحوادث وفق المراحل التالية:
- 7.10.2.1 التحضير (Preparation): تحديد فريق الاستجابة (IRT)، إعداد الأدوات، والتدريب الدوري.
- 7.10.2.2 الكشف والتحليل (Detection & Analysis): مراقبة الأنظمة باستخدام أدوات (IDS/IPS)، وتحليل السجلات لتحديد الحوادث المؤكدة.
- 7.10.2.3 الاحتواء (Containment): عزل الأنظمة المتأثرة مؤقتاً لمنع انتشار الحادث.
- 7.10.2.4 الإزالة (Eradication): معالجة الثغرات وإزالة البرمجيات الخبيثة وإعادة تكوين الأنظمة المتأثرة.
- 7.10.2.5 التعافي (Recovery): استعادة الأنظمة من النسخ الاحتياطية والتأكد من استقرار الخدمة.
- 7.10.2.6 الدروس المستفادة (Lessons Learned): إعداد تقرير نهائي للحادث وتحديث الإجراءات وفق النتائج.
- 7.10.3 يجب على مسؤول الأمن السيبراني (CISO) الإشراف على جميع مراحل إدارة الحوادث، وضمان توثيقها ورفع التقارير إلى الإدارة التنفيذية خلال 24 ساعة من اكتشاف الحادث.
- 7.10.4 يلتزم فريق الاستجابة للحوادث (IRT) بتنفيذ الإجراءات التشغيلية ومعالجة الحالات الطارئة بالتنسيق مع مالك النظام (System Owner) ومالك البيانات (Data Owner) لضمان السرعة والدقة.
- 7.10.5 تُحظر أي محاولة لإخفاء حادث أمني أو تأخير الإبلاغ عنه، ويُعد ذلك مخالفة جسيمة.
- 7.10.6 يجب تنفيذ اختبار سنوي لخطة الاستجابة للحوادث الأمنية، وتوثيق نتائجه في سجل الاختبارات ورفعها إلى لجنة الأمن السيبراني.
- 7.10.7 تُدرج جميع الحوادث الأمنية ضمن سجل الحوادث التقنية، متضمنة نوع الحادث، المسبب، مستوى الخطورة، وقت الكشف، ووقت الإغلاق الفعلي.
- 7.10.8 يُدرج التحليل النهائي للحوادث الأمنية ضمن تقرير الأمن السيبراني ربع السنوي المرفوع إلى لجنة التقنية.
- 7.11 التدريب والجاهزية
- 7.11.1 يجب تنفيذ تدريب نصف سنوي لجميع فرق التشغيل والأمن السيبراني على تطبيق خطط الاستمرارية والتعافي من الكوارث.
- 7.11.2 تشمل التدريبات محاكاة سيناريوهات توقف الخدمة والتعافي السريع لضمان الجاهزية.
- 7.11.3 يُلزم جميع مسؤولي التقنية بالمشاركة في التمارين الفنية واختبارات الطوارئ لضمان استجابة فعالة.
- 7.11.4 تُوثق نتائج التدريب وتقييم الأداء في سجل الجاهزية الفني وتُراجع سنوياً ضمن خطة استمرارية الأعمال.
- 7.12 التطوير والتحسين

7.12.1 يجب مراجعة الأداء التشغيلي للمنصة وتوثيقه بشكل ربع سنوي لتحديد فرص التحسين التقني ورفع نتائج المراجعة للإدارة العليا.

7.12.2 يجب تضمين نتائج المراجعة في خطة التطوير السنوية لضمان التحسين المستمر.

7.12.3 تُحدث السياسة عند صدور أي تعليمات جديدة من الجهات التنظيمية أو عند تغيير بيئة العمل التقنية.

7.12.4 تلتزم الإدارة بتبني التحسينات التقنية التي تعزز الكفاءة التشغيلية واستمرارية الخدمة.

8. مسؤوليات السياسة

8.1 إدارة تقنية المعلومات:

8.1.1 مسؤولون عن تنفيذ هذه السياسة والإشراف على تطبيقها اليومي.

8.2 مسؤول الأمن السيبراني (CISO):

8.2.1 مسؤول عن الإشراف على إدارة المخاطر التقنية والاستجابة للحوادث الأمنية والتأكد من الالتزام بمعايير الأمن.

8.3 إدارة الجودة والتطوير:

8.3.1 مسؤولون عن التأكد من تطبيق هذه السياسات من خلال التدقيق والمراجعة الدورية.

9. التعاميم والتعليمات ذات العلاقة:

9.1 تعليمات الهيئة الوطنية للأمن السيبراني (NCA ECC – Essential Cybersecurity Controls).

9.2 تعليمات هيئة التأمين الخاصة بالحوكمة وحماية البيانات الرقمية.

9.3 أدلة هيئة الحكومة الرقمية المتعلقة بحوكمة التقنية واستمرارية الخدمات.

10. حفظ السياسة:

10.1 تحفظ النسخة الإلكترونية الغير قابلة للنسخ من السياسة المعتمدة على نظام الموارد البشرية ويطلع عليها الإدارات ذات العلاقة.

10.2 تحفظ النسخة الورقية من السياسة المعتمدة في إدارة الجودة والتطوير حسب المدة النظامية المحددة في كتيب تقاؤم المستندات ترحل نظامياً إلى حفظ المستندات.

11. مخالفة السياسة:

11.1 يُطبق في حق المخالف لهذه السياسة ماورد في لائحة جزاءات شركة دايمنود المعتمدة.



Diamond Insurance Broker
Digital Platform Operations
and Business Continuity Policy
Nov 2025

Registered Name: Diamond Insurance Broker Company
Head Office: Al Thumama Road, Al Rabie District, Riyadh
Document Owner: Quality & Development Manager

Internal
DO NOT COPY

Translation

Contents	
1	Introduction.....
2	Policy Objective.....
3	Definitions.....
4	Scope of Application.....
5	Related Management and Sectors.....
6	Related Entity.....
7	General Rules.....
8	Policy Responsibility.....
9	Related Circulars and Instructions.....
10	Policy Retention.....
11	Policy Violation.....



Article (1): This document and the information it contains are related to the Shahin digital platform. They may not be used, copied, or disclosed, in whole or in part, to any third party without the prior written consent of Diamond. This restricted notice may not be altered or removed from this document under any circumstances.

Article (2): In the event of any discrepancy between the Arabic and English texts, the Arabic text shall prevail.

1. Introduction

1.1 The Shahin Digital Platform Operations and Business Continuity Policy is a fundamental component in establishing the operational structure, maintenance, and continuity of the platform in a manner that ensures data integrity, uninterrupted service availability, and the Company's compliance with regulatory and technical standards issued by the Insurance Authority, the Digital Government Authority (DGA), and other relevant entities.

2. Policy Objective

2.1 Diamond Insurance Brokers Company (hereinafter referred to as "Shahin") believes that the objective of this policy is to establish a comprehensive governance and operational framework that ensures the uninterrupted continuity of the Shahin digital platform by regulating maintenance management, backup processes, incident handling, technical risk management, and implementing Disaster Recovery Plans (DRP) and Business Continuity Plans (BCP).

3. Definitions

3.1 Shahin Platform: The Company's digital platform that operates as an insurance broker, connecting with insurance companies to facilitate electronic issuance, renewals, and customer management.

3.2 Business Continuity Plan (BCP): A plan designed to ensure the continuity of operational services in the event of disruption or emergency.

3.3 Disaster Recovery Plan (DRP): A technical recovery plan that defines procedures for restoring services following incidents or data loss.

3.4 Chief Information Security Officer (CISO): The Company's cybersecurity officer responsible for overseeing system protection and ensuring compliance with security standards.

3.5 Incident Response Team (IRT): The team responsible for detecting and addressing technical failures or cyberattacks promptly.

3.6 System Owner: The person/entity responsible for operating the system and overseeing its technical performance and integrity.

3.7 Data Owner: The person/entity responsible for data accuracy and protecting it against unauthorized access.

4. Scope of Application

4.1 This policy applies to all systems, servers, databases, and digital infrastructure related to the Shahin Platform, including operations, monitoring, maintenance, cybersecurity, backup processes, and disaster recovery arrangements.

5. Related Management and Sectors

5.1 Information Technology Department

5.2 Cybersecurity Department

5.3 Quality and Development Department

6. Related Entity

6.1 Insurance Authority

6.2 Digital Government Authority (DGA)

6.3 External technology service providers

7. General Rules

7.1 General Compliance

7.1.1 The Information Technology Department shall ensure the secure and continuous operation of the Shahin Platform and all its digital components, including systems, databases, and integrations with internal and external parties.

7.1.2 The Department shall implement a daily operational plan covering monitoring, maintenance, backup, and incident management to ensure service continuity.

7.1.3 All operational activities shall align with the Company's strategic objectives and cybersecurity requirements issued by relevant regulatory authorities.

7.1.4 No modification, update, or service shutdown of any digital service shall be performed without prior approval from the IT Director and the CISO, and such approval shall be formally documented before implementation.

7.1.5 Operational availability of not less than 99% per month shall be maintained, and immediate corrective action shall be taken upon any performance decline.

7.1.6 The use of any non-officially approved or non-tested external systems, software, or plug-ins within a secure environment is strictly prohibited.

7.2 Technical Operations and Maintenance

7.2.1 The platform shall be continuously monitored 24/7 to detect any failure or service interruption.

7.2.2 Preventive maintenance shall be performed on a scheduled basis, and incidents shall be addressed immediately upon detection without delay.

7.2.3 Maintenance activities during peak operational hours are prohibited except in emergencies and after notifying users.

7.2.4 All operational activities shall adhere to the principle of system stability and shall not adversely impact end users.

7.3 Technical Risk Management

7.3.1 Technical risks shall be identified and analyzed periodically, and preventive actions shall be implemented accordingly. The analysis results and approved treatment actions shall be documented.

7.3.2 Operational risks include system failures, vendor performance weaknesses, and cyberattacks.

7.3.3 Any high-impact risk shall be escalated immediately to executive management, and urgent actions shall be taken to address it.

7.3.4 Delaying or ignoring the treatment of risks classified as High or Critical is strictly prohibited under any circumstances.

7.4 Operational Security and Monitoring

7.4.1 Intrusion Detection and Prevention Systems (IDS/IPS) shall be enabled to monitor unauthorized activities within the platform.

7.4.2 The Department shall activate monitoring and automated alerting capabilities for any potential security threats.

7.4.3 Installing any monitoring tools or collecting operational data using non-approved solutions is prohibited.

7.4.4 The principle of Least Privilege shall be applied to administrative and technical users.

7.5 Change Management and Updates

7.5.1 Prior approval shall be obtained for any modification or update in the production environment, and all change requests and approvals shall be documented.

7.5.2 No change shall be implemented in the production environment unless it has been successfully tested in an independent testing environment, and the technical test results and final deployment approval are documented.

7.5.3 A periodic review mechanism shall be established for all technical changes to ensure alignment with the annual development plan.

7.5.4 Executing any update outside the approved schedule is prohibited unless it is a documented technical emergency.

7.6 Backup and Data Restoration

7.6.1 Automated daily backups shall be performed for all critical systems and databases.

7.6.2 Backups shall be stored in separate secured locations protected against unauthorized access.

7.6.3 Backups shall be periodically tested and documented to confirm restoration capability.

7.6.4 Modifying or deleting backups is prohibited unless officially authorized by the IT Director.

7.7 Business Continuity Plan (BCP)

7.7.1 A Business Continuity Plan shall be developed to ensure the platform continues to deliver services during disruptions or emergencies.

7.7.2 The plan shall identify critical systems, recovery priorities, and automatic failover mechanisms for vital services.

7.7.3 The continuity plan readiness shall be periodically tested and documented to verify its efficiency and response effectiveness.

7.7.4 The plan shall be updated immediately upon any material change in technical infrastructure or operational scope.

7.8 Disaster Recovery Plan (DRP)

7.8.1 A Disaster Recovery Plan shall be established to restore platform services within predefined timelines (RTO/RPO).

7.8.2 The plan shall include an alternative operational environment that can be activated immediately upon the failure of the primary system.

7.8.3 The DRP shall be tested and documented twice annually to ensure effective service restoration.

7.8.4 The DRP shall be fully integrated with the BCP to ensure uninterrupted digital services.

7.9 Technical Incident Management

7.9.1 A technical incident response team shall be established and equipped with the required authorities and tools to address failures immediately.

7.9.2 Incident management shall follow an integrated lifecycle including: preparation, detection, containment, remediation, recovery, and improvement.

7.9.3 Any technical or security incident shall be reported within **two (2) hours** of detection through official channels.

7.9.3.1 All incidents shall be documented after resolution (type, timing, corrective actions, and lessons learned).

7.9.4 Ignoring or delaying response to operational or security incidents is strictly prohibited.

7.9.5 Recurring incidents shall be analyzed, and preventive measures shall be implemented to avoid recurrence.

7.10 Security Incident Management

7.10.1 The IT Department shall implement an approved security incident response framework aimed at early detection, mitigation, and reduction of operational impact.

7.10.2 The Company shall apply an incident response lifecycle including:

7.10.2.1 **Preparation:** Assigning the IRT, preparing tools, and conducting periodic training.

7.10.2.2 **Detection & Analysis:** Monitoring systems using IDS/IPS and analyzing logs to confirm incidents.

7.10.2.3 **Containment:** Temporarily isolating affected systems to prevent spread.

7.10.2.4 **Eradication:** Remediating vulnerabilities, removing malware, and reconfiguring affected systems.

7.10.2.5 **Recovery:** Restoring systems from backups and verifying service stability.

7.10.2.6 Lessons Learned: Issuing a final incident report and updating procedures accordingly.

7.10.3 The CISO shall oversee all security incident management phases, ensure documentation, and submit reports to executive management within **24 hours** of incident detection.

7.10.4 The IRT shall execute operational procedures and emergency handling in coordination with the System Owner and Data Owner to ensure speed and accuracy.

7.10.5 Any attempt to conceal a security incident or delay reporting is strictly prohibited and constitutes a major violation.

7.10.6 An annual test of the security incident response plan shall be conducted, and results shall be documented and submitted to the Cybersecurity Committee.

7.10.7 All security incidents shall be recorded within the technical incident register, including incident type, root cause, severity level, detection time, and actual closure time.

7.10.8 Final security incident analysis shall be incorporated into the quarterly cybersecurity report submitted to the Technical Committee.

7.11 Training and Readiness

7.11.1 Semi-annual training shall be conducted for all operations and cybersecurity teams on the implementation of continuity and disaster recovery plans.

7.11.2 Training shall include simulated scenarios of service disruption and rapid recovery to ensure readiness.

7.11.3 All technical personnel shall participate in technical drills and emergency tests to ensure effective response.

7.11.4 Training results and performance evaluations shall be documented in the technical readiness register and reviewed annually within the BCP framework.

7.12 Development and Continuous Improvement

7.12.1 The platform operational performance shall be reviewed and documented quarterly to identify technical improvement opportunities, and results shall be reported to senior management.

7.12.2 Review outcomes shall be incorporated into the annual development plan to ensure continuous improvement.

7.12.3 This policy shall be updated upon issuance of new regulatory instructions or any change in the technical operating environment.

7.12.4 The Department shall adopt technical enhancements that improve operational efficiency and service continuity.

8. Policy Responsibility

8.1 Information Technology Department: Responsible for implementing this policy and overseeing its daily application.

8.2 Chief Information Security Officer (CISO): Responsible for overseeing technical risk management, security incident response, and compliance with security standards.

8.3 Quality and Development Department: Responsible for ensuring policy implementation through periodic audit and review.

9. Related Circulars and Instructions

9.1 National Cybersecurity Authority (NCA) – Essential Cybersecurity Controls (ECC).

9.2 Insurance Authority instructions related to governance and digital data protection.

9.3 Digital Government Authority (DGA) guidelines related to technology governance and service continuity.

10. Policy Retention

10.1 The approved non-editable electronic version shall be retained in the HR system and made accessible to relevant departments.

10.2 The approved hard copy shall be retained by the Quality and Development Department in accordance with the Document Retention Schedule.

11. Policy Violation

11.1 Any violation of this policy shall be subject to the penalties stipulated in Diamond Insurance Brokers' approved Disciplinary and Sanctions Policy.

